

Wisselbanken RBAC Module: Week-12 QA Report

Release 1 (31 roles). Report date 2026-09-26. Branch fix/p2-cleanup (working tree with uncommitted P2 changes). Prepared for client sign-off under plan section 7.3 (Week 12: full QA across all 31 roles, including solo-operator and registration-bundle edge cases).

1. Summary

Item	Result
Automated suite (sqlite in-memory, full run)	1012 passed, 4 failed, 9759 assertions (1016 tests, 117 s). The 4 failures are the known baseline, section 6.
Release-1 roles checked	31 of 31 (17 Phase 1 + 14 Phase 2). Role names and phases match plan sections 4.1 and 4.2 one-to-one: yes.
Role x group cells (31 x 25 = 775)	Seeded database equals the seeder's matrix file in 775 of 775 cells; every seeded level is one of F/A/O/S/R: yes. This is a self-consistency check, not a plan comparison (section 3).
Plan-stated cells	20 of 20 pass (section 4).
Live engine checks (real checkPermission / routing / onboarding calls)	36 of 37 pass; 1 fail (section 5, check D-auditor_read_all).
Registration bundles	All 19 org types x 4 team sizes executed through the onboarding service; results in section 7.
Discrepancies plan vs seed	6 items (section 2 and section 9).
Not proven	See section 10. Nothing in this report proves production behaviour or MariaDB-only behaviour.

2. Basis of the comparison and what the plan does and does not say

Plan source: Revised RBAC Module Implementation Plan (PDF, Release 1). It is not stored in the repository; it was read from the local file `~/Downloads/Wiselbanen_RBAC/Revised_RBAC_Module_Implementation_Plan.pdf`. The client's role-permission spreadsheet (the 'RBAC Matrix v2' that the seeder header says the matrix was generated from) is not in the repository and was not found on this machine.

Consequence: the plan text states expectations for only a small number of cells (spot checks in section 2.4, the crosswalk access model in section 4.6, the RFQ flow levels in section 6.6). For every other role x group cell there is no plan expectation in any document available here. For those cells this report compares the seeded database against the seeder's own source-of-truth file (`database/seeder/Rbac/data/role_permission_matrix.php`) and labels it as such. That comparison shows the seeding is faithful; it does not show the matrix is what the client intended.

Plan statement	Plan	Seed	Status
Roles in Release 1	31 (17 Phase 1 + 14 Phase 2, sections 4.1, 4.2)	31 roles with phase P1 or P2, names identical	Match
Total roles seeded	31 (Release 2 deferred)	49 (31 Release 1 + 18 Release 2 roles with phase P3)	Expected: seed carries the Release 2 superset

Plan statement	Plan	Seed	Status
api_system role	Not in the 31 (section 4.1/4.2)	Seeded with phase P3	Client decision pending: P2 would make Release 1 = 32 (SeedMatrixTest expects P2)
Permission groups	24 (section 3.1)	25: the 24 plan groups plus System Administration	Differs; client decision pending (24 vs 25)
Organization types	'20 types' (section 4.4 heading and 2.4)	19 (the plan's own table lists 19 rows, numbered 1 to 19)	Plan is internally inconsistent; seed matches the plan's table; client decision pending
Crosswalk permission entry	'A permission-group entry' (section 4.6)	No dedicated group; code gates crosswalk with estimate_management (route map: GET/PUT/DELETE plan-crosswalk, POST projects/{project}/crosswalk)	Differs; client decision pending (crosswalk group)
Project Manager and crosswalk	Section 4.6: 'all projects in their org'; section 3.5: no access to a project they are not assigned to	Code follows section 3.5: PM must be an active project member (check C2b)	Plan sections contradict each other; code follows 3.5
Small distributor bundle	Section 6.1 names 'Manufacturer, solo or small'	config/rbac.php also gives distributor_stocking and distributor_non_stocking the manufacturer bundle	Extension beyond the plan text; confirm with client

3. Role x permission group results (31 Release-1 roles)

Column 'DB = file' counts cells (out of 25) where the level in the seeded database equals the level in the seeder's matrix file. 'Plan-stated cells' counts the cells for which the plan gives an explicit expectation (section 4); most roles have none. 'Grants' is the number of groups where the role has any level; the other groups are 'no access', which is how the matrix file defines an absent entry.

Role	Plan phase	Seed phase	Grants	Levels held (count)	Strongest	DB = file	Plan-stated cells	Result
Platform Super Admin	P1	P1	25	F:25	F	25/25	none stated	PASS
Platform Data Reviewer	P1	P1	14	A:1 R:13	A	25/25	none stated	PASS
Platform Catalog Admin	P1	P1	8	F:2 A:1 R:5	F	25/25	none stated	PASS
Integration / Service Account	P1	P1	8	F:4 R:4	F	25/25	none stated	PASS
Auditor / Read-All	P1	P1	15	F:1 R:14	F	25/25	none stated	PASS
Organization Owner	P1	P1	18	F:10 A:2 R:6	F	25/25	none stated	PASS
Organization Admin	P1	P1	14	F:3 O:1 S:1 R:9	F	25/25	none stated	PASS
Executive Approver	P1	P1	10	A:4 R:6	A	25/25	2/2 pass	PASS
Project Manager	P1	P1	12	F:4 S:2 R:6	F	25/25	1/1 pass	PASS
Estimator	P1	P1	8	F:4 S:1 R:3	F	25/25	1/1 pass	PASS
Viewer / Read Only	P1	P1	8	R:8	R	25/25	none stated	PASS
Procurement Manager	P1	P1	14	F:3 A:1 R:10	F	25/25	5/5 pass	PASS
Requisitioner	P1	P1	7	S:2 R:5	S	25/25	3/3 pass	PASS
Manufacturer Admin	P1	P1	14	F:10 A:3 R:1	F	25/25	1/1 pass	PASS
Product Manager	P1	P1	8	F:2 O:1 R:5	F	25/25	1/1 pass	PASS
Catalog Data Steward	P1	P1	6	F:1 O:1 S:1 R:3	F	25/25	1/1 pass	PASS
Order Fulfillment / CSR	P1	P1	7	F:2 R:5	F	25/25	1/1 pass	PASS
Platform Operations	P2	P2	18	F:5 O:1 R:12	F	25/25	none stated	PASS
Platform Finance / Billing	P2	P2	6	F:3 R:3	F	25/25	none stated	PASS
Financial Admin	P2	P2	15	F:3 A:1 O:1 R:10	F	25/25	none stated	PASS
Contract Manager	P2	P2	9	F:1 S:1 R:7	F	25/25	none stated	PASS
AP / Invoice Clerk	P2	P2	7	F:1 O:1 R:5	F	25/25	none stated	PASS

Role	Plan phase	Seed phase	Grants	Levels held (count)	Strongest	DB = file	Plan-stated cells	Result
Budget Owner	P2	P2	10	A:1 R:9	A	25/25	none stated	PASS
Procurement Coordinator	P2	P2	7	F:1 O:1 R:5	F	25/25	none stated	PASS
Pricing Manager	P2	P2	7	A:1 R:6	A	25/25	1/1 pass	PASS
Sales Rep	P2	P2	6	F:1 R:5	F	25/25	1/1 pass	PASS
Compliance / Certifications	P2	P2	2	F:1 R:1	F	25/25	1/1 pass	PASS
Inventory Manager	P2	P2	2	F:1 R:1	F	25/25	1/1 pass	PASS
Architect	P2	P2	6	S:1 R:5	S	25/25	none stated	PASS
Engineer	P2	P2	5	A:1 R:4	A	25/25	none stated	PASS
Delegate / Proxy	P2	P2	5	O:1 R:4	O	25/25	none stated	PASS

Result FAIL would mean a mismatch in either comparison. The Auditor / Read-All observation in section 5 is a separate role-description check and is not counted here.

3.1 Full seeded matrix (Release-1 roles)

Cell = seeded access level; a dot means no access. Column keys: 1 Organization Management; 2 User Management; 3 Project Management; 4 Estimate Management; 5 Procurement; 6 Product Management; 7 Pricing Management; 8 Approval Authority; 9 Financial Access; 10 Manufacturer Controls; 11 Reporting & Analytics; 12 AI Extraction Review; 13 System Administration; 14 Quote / RFQ Management; 15 Contract & Agreement Management; 16 Invoice & Payment Processing; 17 Order Fulfillment; 18 Returns & RMA; 19 Catalog Taxonomy & Data Quality; 20 Compliance & Certification; 21 Budget & Cost Control; 22 Delegation & Impersonation; 23 Audit & Logging; 24 Seller Payout & Settlement; 25 Inventory & Availability.

Role	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25
Platform Super Admin	F	F	F	F	F	F	F	F	F	F	F	F	F	F	F	F	F	F	F	F	F	F	F	F	F
Platform Data Reviewer	R	R	R	R	R	R	R	.	.	R	R	A	.	R	.	.	R	.	R	.	.	.	R	.	.
Platform Catalog Admin	.	.	.	.	.	F	R	.	.	R	R	A	.	.	.	.	R	.	F	.	.	.	R	.	.
Integration / Service Account	.	.	.	.	R	F	F	.	.	R	.	.	.	R	.	.	F	.	R	.	.	.	.	.	F
Auditor / Read-All	F	R	R	R	R	R	R	.	R	R	R	.	.	R	.	.	R	.	R	.	.	R	R	.	.
Organization Owner	F	F	F	F	F	R	R	A	F	.	F	.	R	F	F	.	R	.	.	.	A	F	R	R	.
Organization Admin	F	F	F	R	R	R	R	S	.	.	R	.	R	R	.	.	R	.	.	.	.	O	R	.	.
Executive Approver	.	.	R	R	R	.	R	A	R	.	R	.	.	A	A	.	.	.	.	.	A	.	.	.	.
Project Manager	.	S	F	F	F	R	R	S	.	.	R	.	.	F	.	.	R	.	.	.	R	.	R	.	.
Estimator	.	F	F	F	F	R	R	.	.	.	.	.	.	S	.	.	R	.	.	.	.	.	.	.	.
Viewer / Read Only	.	.	R	R	R	R	R	.	.	.	R	.	.	R	.	.	R	.	.	.	.	.	.	.	.
Procurement Manager	R	R	R	R	F	R	R	A	.	.	R	.	.	F	F	.	R	.	.	.	R	.	R	.	.
Requisitioner	.	.	R	R	S	R	R	.	.	.	.	.	.	S	.	.	R	.	.	.	.	.	.	.	.
Manufacturer Admin	F	F	.	.	.	F	F	A	.	F	F	.	.	F	.	.	F	A	F	.	.	.	R	A	F
Product Manager	.	.	.	.	.	F	R	.	.	O	.	.	.	R	.	.	R	.	F	R	.	.	.	.	R
Catalog Data Steward	.	.	.	.	.	O	R	.	.	R	.	S	.	.	.	.	R	.	F	.	.	.	.	.	.
Order Fulfillment / CSR	.	.	.	.	R	R	R	.	.	.	.	.	.	R	.	.	F	F	.	.	.	.	.	.	R
Platform Operations	R	F	R	R	R	R	R	R	.	R	F	F	F	R	.	.	R	.	R	R	.	O	F	.	.
Platform Finance / Billing	R	.	.	.	.	.	.	.	F	.	R	.	.	.	.	F	.	.	.	.	.	.	R	F	.
Financial Admin	R	O	R	R	R	.	R	A	F	.	R	.	.	R	.	F	R	.	.	.	F	.	R	R	.
Contract Manager	.	.	R	R	.	R	R	S	.	.	R	.	.	R	F	.	R	.	.	.	.	.	.	.	.
AP / Invoice Clerk	.	.	R	R	R	.	.	.	O	.	.	.	.	R	.	F	R	.	.	.	.	.	.	.	.
Budget Owner	R	.	R	R	R	.	R	.	R	.	R	.	.	R	.	.	R	.	.	.	A	.	.	.	.
Procurement Coordinator	.	.	R	R	O	R	R	.	.	.	.	.	.	F	.	.	R	.	.	.	.	.	.	.	.
Pricing Manager	.	.	.	.	.	R	A	.	.	R	R	.	.	.	R	.	R	.	R	.	.	.	.	.	.
Sales Rep	.	.	.	.	.	R	R	.	.	R	.	.	.	F	.	.	R	R	.	.	.	.	.	.	.

Role	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25
Compliance / Certifications	.	.	.	.	.	R	.	.	.	.	.	.	.	.	.	.	.	.	.	F	.	.	.	.	.
Inventory Manager	.	.	.	.	.	.	.	.	.	.	.	.	.	.	.	.	R	.	.	.	.	.	.	.	F
Architect	.	.	R	R	.	R	R	.	.	.	.	.	.	S	.	.	.	.	.	R	.	.	.	.	.
Engineer	.	.	R	R	.	R	.	.	.	.	.	.	.	A	.	.	.	.	.	R	.	.	.	.	.
Delegate / Proxy	.	.	R	R	R	.	.	.	.	.	.	.	.	R	.	.	.	.	.	.	.	O	.	.	.

4. Plan-stated cells

Every cell for which the plan text gives an explicit expectation, compared with the seeded level. 'Crosswalk' cells are checked on estimate_management because that is the group the code uses for the crosswalk.

Role	Group	Plan expectation	Seeded level	Result	Plan reference	Note
Requisitioner	procurement	S (Submit)	S	PASS	Plan §2.4 spot check	
Executive Approver	approval_authority	A (Approve)	A	PASS	Plan §2.4 spot check	
Estimator	estimate_management	F (crosswalk)	F	PASS	Plan §4.6	crosswalk uses estimate_management in code
Project Manager	estimate_management	F (crosswalk)	F	PASS	Plan §4.6	crosswalk uses estimate_management in code
Procurement Manager	estimate_management	R (crosswalk)	R	PASS	Plan §4.6	
Requisitioner	estimate_management	R (crosswalk)	R	PASS	Plan §4.6	
Executive Approver	estimate_management	R (crosswalk)	R	PASS	Plan §4.6	
Manufacturer Admin	estimate_management	none (crosswalk)	none	PASS	Plan §4.6	
Product Manager	estimate_management	none (crosswalk)	none	PASS	Plan §4.6	
Catalog Data Steward	estimate_management	none (crosswalk)	none	PASS	Plan §4.6	
Order Fulfillment / CSR	estimate_management	none (crosswalk)	none	PASS	Plan §4.6	
Pricing Manager	estimate_management	none (crosswalk)	none	PASS	Plan §4.6	
Sales Rep	estimate_management	none (crosswalk)	none	PASS	Plan §4.6	
Compliance / Certifications	estimate_management	none (crosswalk)	none	PASS	Plan §4.6	
Inventory Manager	estimate_management	none (crosswalk)	none	PASS	Plan §4.6	
Requisitioner	quote_rfq_management	S or higher (request)	S	PASS	Plan §6.6 step 1	
Procurement Manager	quote_rfq_management	S or higher (request)	F	PASS	Plan §6.6 step 1	
Procurement Manager	quote_rfq_management	O or F (review)	F	PASS	Plan §6.6 step 2	
Procurement Manager	quote_rfq_management	F (convert)	F	PASS	Plan §6.6 step 3	
Procurement Manager	procurement	S or higher (convert)	F	PASS	Plan §6.6 step 3	

5. Plan spot checks and live engine checks, executed

Executed against the in-memory sqlite copy of the seeded matrix by calling `PermissionService::checkPermission()`, `ApprovalRoutingService::route()` and `OrgOnboardingService::onboard()` with real users, orgs, roles and project memberships. No MySQL/MariaDB connection was opened; the harness refuses to run unless the connection is in-memory sqlite. 'allow' means `checkPermission` returned true.

ID	Source	Check	Expected	Actual	Result
S1	Plan §2.4	Requisitioner has Submit on Procurement: <code>checkPermission(procurement, S)</code>	allow	allow	PASS
S1n	Plan §2.4 (negative)	Requisitioner does NOT have Approve on Procurement: <code>checkPermission(procurement, A)</code>	deny	deny	PASS
S2	Plan §2.4	Executive Approver has Approve on Approval Authority: <code>checkPermission(approval_authority, A)</code>	allow	allow	PASS
S2n	Plan §2.4 / roles.php (negative)	Requisitioner "cannot approve": no Approval Authority at A	deny	deny	PASS
S3	SeedMatrixTest (not in plan text)	Platform Super Admin holds Full on all 25 groups	allow	allow	PASS
S4	Plan §3.4	Executive Approver in org A has no rights in org B (org_id scoping)	deny	deny	PASS
C1	Plan §4.6	Estimator: F on crosswalk group, on assigned project A	allow	allow	PASS
C1b	Plan §4.6	Estimator on Project A cannot act on Project B (not a member)	deny	deny	PASS
C2	Plan §4.6	Project Manager: F on crosswalk group, project A	allow	allow	PASS
C2b	Plan §4.6	Project Manager, not enrolled on B: denied on project B	deny	deny	PASS
C3-procurement_manager-R	Plan §4.6	Procurement Manager: Read on crosswalk group (project A member)	allow	allow	PASS
C3-procurement_manager-F	Plan §4.6 (negative)	Procurement Manager: not Full (Read only)	deny	deny	PASS
C3-requisitioner-R	Plan §4.6	Requisitioner: Read on crosswalk group (project A member)	allow	allow	PASS
C3-requisitioner-F	Plan §4.6 (negative)	Requisitioner: not Full (Read only)	deny	deny	PASS
C3-executive_approver-R	Plan §4.6	Executive Approver: Read on crosswalk group (project A member)	allow	allow	PASS
C3-executive_approver-F	Plan §4.6 (negative)	Executive Approver: not Full (Read only)	deny	deny	PASS
C4-manufacturer_admin	Plan §4.6	Manufacturer Admin (seller role): no crosswalk access at all (even R)	deny	deny	PASS
C4-product_manager	Plan §4.6	Product Manager (seller role): no crosswalk access at all (even R)	deny	deny	PASS
C4-catalog_data_steward	Plan §4.6	Catalog Data Steward (seller role): no crosswalk access at all (even R)	deny	deny	PASS
C4-order_fulfillment_csr	Plan §4.6	Order Fulfillment Csr (seller role): no crosswalk access at all (even R)	deny	deny	PASS

ID	Source	Check	Expected	Actual	Result
C4-pricing_manager	Plan §4.6	Pricing Manager (seller role): no crosswalk access at all (even R)	deny	deny	PASS
C4-sales_rep	Plan §4.6	Sales Rep (seller role): no crosswalk access at all (even R)	deny	deny	PASS
C4-compliance_certifications	Plan §4.6	Compliance Certifications (seller role): no crosswalk access at all (even R)	deny	deny	PASS
C4-inventory_manager	Plan §4.6	Inventory Manager (seller role): no crosswalk access at all (even R)	deny	deny	PASS
R1	Plan §6.6 step 1	Requisitioner: Submit on Quote/RFQ	allow	allow	PASS
R1b	Plan §6.6 step 1	Procurement Manager: Submit on Quote/RFQ	allow	allow	PASS
R2	Plan §6.6 step 2	Procurement Manager: Own or Full on Quote/RFQ (review)	allow	allow	PASS
R2n	Plan §6.6 step 2 (negative)	Requisitioner (Submit only) cannot review: no Own on Quote/RFQ	deny	deny	PASS
R3	Plan §6.6 step 3	Convert to PO needs F on Quote/RFQ AND S on Procurement: Procurement Manager	allow	allow	PASS
R3n	Plan §6.6 step 3 (negative)	Convert to PO: Requisitioner denied (no F on Quote/RFQ)	deny	deny	PASS
R4	Plan §6.6	Read-only Viewer can view but not submit on Quote/RFQ	deny	deny	PASS
D-viewer_read_only	Role description (roles.php), not plan cell data	Viewer / Read Only: no level stronger than R in any group	R	R	PASS
D-auditor_read_all	Role description (roles.php), not plan cell data	Auditor / Read-All: no level stronger than R in any group	R	F	FAIL
A1	Plan §6.2	Sole approver is the requester: auto-approve, nobody to route to	auto=1;route=[]	auto=1;route=[]	PASS
A2	Plan §6.2	Two approvers, requester is one: NOT auto-approved; routed to the other only	auto=0;route=[other]	auto=0;route=[other]	PASS
A3	Plan §6.2	Requester is not an approver: routed to the approver pool	auto=0;route=[approver]	auto=0;route=[approver]	PASS
A4	Code behaviour (plan silent)	Zero approvers in org: service returns auto=0 and empty route (checkout/RFQ convert refuse the order, see tests)	auto=0;route=[]	auto=0;route=[]	PASS

Finding (check D-auditor_read_all): the seeded Auditor / Read-All role holds F (Full) on organization_management (all its other 14 grants are R). The role description in the seed is 'Read-only across org for audit/compliance'. In config/route_permission_map.php, POST org-admin/settings and POST/DELETE org-admin/connections require organization_management F, so an Auditor can pass those checks. This is a matrix value (client-supplied), not a code defect; it is listed for a client decision and is not changed by this report. The existing test AuditFindingsRound2Test documents the same grant.

6. Automated test coverage

Framework: PHPUnit (the repository has no Pest). Full run: DB_CONNECTION=sqlite DB_DATABASE=:memory: php artisan test. Result: 1012 passed, 4 failed (1016 tests, 9759 assertions).

Area	Test class	What it covers	Tests	Passed	Failed
Seed matrix and permission engine	SeedMatrixTest	Seed counts, phase split, plan §2.4 spot checks, idempotence	4	2	2
Seed matrix and permission engine	PermissionServiceTest	checkPermission(): org scoping, level hierarchy, project scope	8	8	0
Seed matrix and permission engine	RoutePermissionMapTest	Lint of config/route_permission_map.php against registered routes	14	14	0
Seed matrix and permission engine	DelegationTest	Time-bound delegation	8	8	0
Seed matrix and permission engine	ServiceAccountTest	API tokens / service accounts	10	10	0
Seed matrix and permission engine	SodTest	Separation-of-duties conflicts on role assignment	5	5	0
Seed matrix and permission engine	RoleAssignmentTest	Role assignment and peel-off (plan §6.3)	4	4	0
Seed matrix and permission engine	RoleAssignmentLogTest	Role-assignment log	5	5	0
Registration bundles and solo-operator rule	OrgOnboardingTest	Registration bundles (plan §6.1)	6	6	0
Registration bundles and solo-operator rule	ApprovalRoutingTest	Sole-approver auto-approve rule (plan §6.2)	3	3	0
Audit / enforce middleware	AuditMiddlewareTest	Audit vs enforce mode, blocked-request logging	5	4	1
Audit / enforce middleware	AuditFindingsTest	Client audit 1.0: controller-level checks and view gating, audit and enforce	54	54	0
Audit / enforce middleware	AuditFindingsRound2Test	Every mapped route as viewer / no-grant user, audit and enforce	54	54	0
Audit / enforce middleware	AuditMembershipLogTest	project_member_logs on every membership change	28	28	0
Projects and project-scoped access	ProjectSchemaTest	Projects schema, guards, ProjectMember::enrol()	41	41	0

Area	Test class	What it covers	Tests	Passed	Failed
Projects and project-scoped access	ProjectMembershipTest	Project membership and quote_param/project_param resolution	57	57	0
Projects and project-scoped access	ProjectReadPathsTest	Read paths, per-route allow/deny matrix, audit-mode guarantee	151	151	0
Projects and project-scoped access	ProjectWritePathsTest	Project CRUD, membership, quote creation, crosswalk, IDOR	100	100	0
Projects and project-scoped access	ProjectCheckpoint2Test	Owner-level checks, user-delete cleanup, crosswalk project list	57	57	0
Projects and project-scoped access	ProjectDeletionRefusalTest	Org/user deletion refused while projects exist	19	19	0
Projects and project-scoped access	ProjectDashboardCountersTest	Dashboard counters use the same scope as the quotes index	24	24	0
Projects and project-scoped access	ProjectWalkthroughFixesTest	Page renders and walkthrough fixes	19	19	0
Projects and project-scoped access	QuoteAuthorScopeGuardTest	Text scan: no quote visibility by user_id	4	4	0
Data migration (Phase 2 backfill, Phase 5b)	ProjectBackfillTest	projects:backfill command	77	77	0
Data migration (Phase 2 backfill, Phase 5b)	Phase5MigrationsTest	Phase 5b tightening migrations and their guards	84	84	0
RFQ, checkout and approvals	RfqProjectScopeTest	RFQ project scope, seller isolation, convert needs F + procurement S, approval routing	104	104	0
RFQ, checkout and approvals	P2CleanupBCTest	Zero-approver refusal, sole/several approvers at checkout and RFQ convert, pending approvals/RFQs, respond status checks, delete-user log	69	69	0
Laravel scaffolding	Feature/ExampleTest	Home page smoke test (needs the full app schema)	1	0	1
Laravel scaffolding	Unit/ExampleTest	Scaffolding	1	1	0

Totals: 1016 tests, 1012 passed, 4 failed. All Rbac tests use a fresh in-memory sqlite database built from the real RBAC migrations (see RbacTestCase).

6.1 The 4 failing tests (known baseline, not regressions)

Test	Failure	Cause
AuditMiddlewareTest::test_enforce_mode_blocks_and_records_blocked ('enforce mode blocks and logs')	Expects 403, gets a 302 redirect	Non-JSON denials redirect back by design in RbacAudit::fail(); the test predates that. Needs a decision on intended behaviour.

Test	Failure	Cause
SeedMatrixTest::test_seeds_expected_counts ('seeds expected counts')	Expects 20 org types, finds 19	Plan says 20 but lists 19; client decision pending.
SeedMatrixTest::test_phase_distribution ('phase distribution')	Expects 15 P2 roles, finds 14	api_system is seeded as P3; test expects P2. Client decision pending.
Feature/ExampleTest::test_the_application_returns_a_successful_response	no such table: divisions	Scaffolding test that needs the full app schema, which cannot be migrated on empty sqlite (see RbacTestCase note).

The two SeedMatrixTest failures are deliberately left as they are until the client decides; the tests were not edited to match either side.

SeedMatrixTest::test_spot_checks_from_the_plan passes.

7. Registration-bundle edge cases (plan section 6.1)

Every organization type (19) at every team size was registered through `OrgOnboardingService::onboard()`, and the resulting active roles were read back. Code source: `config/rbac.php` (small_team_sizes = solo, 2-5; buyer types = subcontractor, general_contractor, owner; manufacturer types = manufacturer, distributor_stocking, distributor_non_stocking).

Org type	Solo	2-5	6-20	20+
owner	Buyer bundle (4)	Buyer bundle (4)	Owner only	Owner only
architect	Owner only	Owner only	Owner only	Owner only
engineering_firm	Owner only	Owner only	Owner only	Owner only
general_contractor	Buyer bundle (4)	Buyer bundle (4)	Owner only	Owner only
subcontractor	Buyer bundle (4)	Buyer bundle (4)	Owner only	Owner only
manufacturer	Manufacturer bundle (3)	Manufacturer bundle (3)	Owner only	Owner only
fabricator	Owner only	Owner only	Owner only	Owner only
distributor_stocking	Manufacturer bundle (3)	Manufacturer bundle (3)	Owner only	Owner only
distributor_non_stocking	Manufacturer bundle (3)	Manufacturer bundle (3)	Owner only	Owner only
logistics_provider	Owner only	Owner only	Owner only	Owner only
consultant	Owner only	Owner only	Owner only	Owner only
service_vendor	Owner only	Owner only	Owner only	Owner only
platform_internal	Owner only	Owner only	Owner only	Owner only
buying_group_gpo	Owner only	Owner only	Owner only	Owner only
manufacturer_s_rep_sales_agency	Owner only	Owner only	Owner only	Owner only
testing_certification_body	Owner only	Owner only	Owner only	Owner only
government_ahj	Owner only	Owner only	Owner only	Owner only
rental_equipment_provider	Owner only	Owner only	Owner only	Owner only
financial_surety_partner	Owner only	Owner only	Owner only	Owner only

- Buyer bundle = Organization Owner + Procurement Manager + Estimator + Executive Approver (matches plan section 6.1). Manufacturer bundle = Manufacturer Admin + Product Manager + Catalog Data Steward (matches). Larger teams and all other types: Organization Owner only (matches).
- Team size '2-5' is treated as small (gets the bundle); the plan says 'solo or small' and lists sizes Solo / 2-5 / 6-20 / 20+.
- Distributors (stocking and non-stock) receive the manufacturer bundle. The plan text names only 'Manufacturer' for that bundle.

- Onboarding deliberately bypasses separation-of-duties (code comment in OrgOnboardingService): the buyer bundle holds Procurement Manager, Estimator and Executive Approver together, which SodConflictRuleSeeder would otherwise block on manual assignment. Peel-off (plan section 6.3) is covered by RoleAssignmentTest (4 tests).
- Onboarding is idempotent: re-running seedOrgRoles does not duplicate rows (test_seed_org_roles_is_idempotent).
- Roles that carry Approval Authority at A or F in the seed: platform_super_admin=F, organization_owner=A, executive_approver=A, financial_admin=A, procurement_manager=A, manufacturer_admin=A.
- Because Organization Owner and Manufacturer Admin carry Approval Authority A, every freshly registered org in this run (all 76 combinations) has exactly one approver, the registering user, and auto-approve applies to that user: confirmed for all 76.

8. Solo-operator auto-approve edge cases (plan section 6.2)

Case	Expected (plan)	Result	Evidence
Sole approver is the requester	Auto-approve, no routing	PASS	Live check A1; ApprovalRoutingTest::test_sole_approver_auto_approves
Two approvers, requester is one	No auto-approve; routed to the other approver only	PASS	Live check A2; ApprovalRoutingTest::test_two_approver_org_does_not_auto_approve_and_routes_to_the_other
Requester is not an approver	Routed to the whole approver pool	PASS	Live check A3; ApprovalRoutingTest::test_non_approver_requester_routes_to_full_pool
No approver in the org	Not specified in the plan; decided in P2-C: refuse the order with a message, create nothing	Service returns no route (A4); checkout and RFQ convert refuse (browser: redirect with error; JSON: 422); retry works once an approver exists	P2CleanupBCTest: checkout and convert, no approver / sole approver / several approvers / non-approver, audit and enforce mode
Approver pool definition	Users with Approval Authority 'A'	Code also counts 'F' as an approver (F outranks A); Platform Super Admin holds F	ApprovalRoutingService::approverPool
RFQ convert routing	Follows standard approval routing (section 6.6)	Convert requires quote_rfq_management F and procurement S and uses ApprovalRoutingService	RfqProjectScopeTest (104 tests)

9. Discrepancies between plan and seed (summary)

- Permission groups: plan 24, seed 25 (System Administration is the extra group).
- Organization types: plan heading says 20, the plan's table and the seed have 19.
- `api_system`: not among the plan's 31 roles; seeded as P3 (Release 2). The `SeedMatrixTest` expectation of P2 (Release 1 = 32) conflicts with the plan's 31.
- Crosswalk has no group of its own; it reuses `estimate_management`. Under that group, Requisitioner, Procurement Manager and Executive Approver have R, Estimator and Project Manager have F, and no seller role has any level, all as the plan's section 4.6 table says.
- Plan sections 4.6 and 3.5 disagree on whether a Project Manager reaches projects they are not a member of; the code enforces membership.
- Auditor / Read-All holds F on `organization_management` while described as read-only.
- Distributors receive the manufacturer registration bundle; the plan names only Manufacturer.
- For all other role x group cells the plan gives no expectation; they can only be checked against the seeder's own matrix file.

10. NOT proven

These are the limits of this report. Read them before signing off.

- `sqlite` only. Every test and every check above ran on in-memory `sqlite`. Behaviour of MariaDB/MySQL (DDL, collations, locking, foreign-key cascades, timezone handling) is not proven.
- MariaDB-only behaviours never run: the `ProjectMember::enrol()` race, `SELECT ... FOR UPDATE` locking, and the `quotes.user_id` cascade.
- Production state is unverified. Statements that production runs the current release with `APP_DEBUG=false` and RBAC enforcement on are reports, not something checked here. No staging environment exists; real-403 testing on a live stack has not been done.
- Matrix decisions pending with the client and reflected in failing or ambiguous checks: organization types 19 vs 20, `api_system` P2 vs P3 (Release 1 = 31 vs 32), permission groups 24 vs 25 (and a dedicated crosswalk group). The two `SeedMatrixTest` failures stay until these are decided.
- The client's per-cell role-permission spreadsheet was not available, so the 775-cell matrix is proven faithful to the seeder file only, not correct against the client's intent.
- Delegation (plan question Q11) is undecided. A delegate is checked against the principal's roles but projects are scoped by the delegate's own user id, so a delegate can pass a check and then get a 404.
- Phase 5b (three irreversible tightening migrations) has not been run anywhere; Phase 5b behaviour is proven only against the `sqlite` test schema.
- Accepted audit-mode behaviours: in audit mode the middleware only logs, so some reads (`quotes list/details/pdf`, `projects list/show`, `plan-crosswalk index`) return filtered or empty data or 404 rather than 403 (controller data scoping is the guard), and writes on a hidden `project/quote/RFQ` answer 404 before 403. These are documented in `AuditFindingsRound2Test` and were accepted, not eliminated.
- Known dead code: `OrgRelationshipService::sellerAuthorizationError()` compares org type to `'rep_agency'` but the real slug is `'manufacturer_s_rep_sales_agency'`, so rep-agency seller authorization is not enforced.
- The suite has no browser/UI test; page rendering is covered only by feature tests that render views on `sqlite`.

11. How this report was produced

- Seeded matrix read by running RbacSeeder against in-memory sqlite through a throwaway script (outside the repository); compared cell by cell with database/seeders/Rbac/data/role_permission_matrix.php.
- Live checks call the real services with real rows; the suite was run in full with DB_CONNECTION=sqlite DB_DATABASE=:memory: php artisan test and per-class counts were taken from its JUnit output.
- No application code, tests or other documents were modified. Files produced: docs/WEEK12-QA-REPORT.md, .html and .pdf.